



Utkarsh Arora <utkarsh20143@iiitd.ac.in>

Report issue - Group 37

3 messages

Google Forms <forms-receipts-noreply@google.com>
To: utkarsh20143@iiitd.ac.in

Mon, Dec 5, 2022 at 12:06 AM

Thanks for filling out [Report issue - Group 37](#)

Here's what was received.

Report issue - Group 37

Please fill out this form to report an issue/vulnerability in the group 37.

Your email (utkarsh20143@iiitd.ac.in) was recorded when you submitted this form.

Vulnerability type

*

Select the type of vulnerability, or specify a custom one.

☐ XSS

☐ CSRF

☐ Feature bug

☒ Other: Access control

Steps to reproduce

*

Describe the steps to reproduce the vulnerability.

All the frontend code is available by accessing the source.

By parsing the JavaScript code, we can find the APIs used to retrieve user information.

These APIs are supposed to be called by the admin portal.

These APIs can be accessed by anyone directly, because they haven't used any security feature like JWT.

Proof of concept

*

Provide a proof of concept for the vulnerability.

I found access to two APIs:

<https://192.168.3.106:5000/api/getAllUserFalse>

<https://192.168.3.106:5000/api/getAllUserTrue>

These APIs show all the user data, INCLUDING unhashed passwords

This info provides for tremendous amount of further exploits

Impact

*

Describe the impact of the vulnerability. How bad is it?

Severe; all the passwords of the users can be accessed

Screenshots/attachments

Provide screenshots or other attachments to help explain the vulnerability.

Submitted files



fcs_37_2_1 - Utkarsh Arora.png



fcs_37_2_2 - Utkarsh Arora.png



fcs_37_2_3 - Utkarsh Arora.png



fcs_37_2_4 - Utkarsh Arora.png

Create your own Google Form

Report Abuse

Thanks for filling out [Report issue - Group 37](#)

Here's what was received.

Report issue - Group 37

Please fill out this form to report an issue/vulnerability in the group 37.

Your email (utkarsh20143@iiitd.ac.in) was recorded when you submitted this form.

Vulnerability type

*

Select the type of vulnerability, or specify a custom one.

☐ XSS

☐ CSRF

☐ Feature bug

☒ Other:

Steps to reproduce

*

Describe the steps to reproduce the vulnerability.

All the frontend code is available by accessing the source.

By parsing the JavaScript code, we can find the APIs used to retrieve user information.

These APIs are supposed to be called by the admin portal.

These APIs can be accessed by anyone directly, because they haven't used any security feature like JWT.

Proof of concept

*

Provide a proof of concept for the vulnerability.

I found two more APIs which are further ripe for abuse:

https://192.168.3.106:5000/api/deleteUser/\${id}

https://192.168.3.106:5000/api/userapprove/\${id}

Using these, without even having admin credentials, I can approve or delete users from the

system. This is a huge privilege escalation.

I have used the python requests library to POST a request to delete one such user from the system

Impact

*

Describe the impact of the vulnerability. How bad is it?

Huge, the admin APIs can be abused, and frivolous users can be approved and legitimate users can be deleted by anyone without even having admin access

Screenshots/attachments

Provide screenshots or other attachments to help explain the vulnerability.

Submitted files



fcs_37_3_1 - Utkarsh Arora.png



fcs_37_3_2 - Utkarsh Arora.png



fcs_37_3_3 - Utkarsh Arora.png

[Quoted text hidden]

Google Forms <forms-receipts-noreply@google.com>
To: utkarsh20143@iiitd.ac.in

Mon, Dec 5, 2022 at 3:24 AM

Thanks for filling out [Report issue - Group 37](#)

Here's what was received.

Report issue - Group 37

Please fill out this form to report an issue/vulnerability in the group 37.

Your email (utkarsh20143@iiitd.ac.in) was recorded when you submitted this form.

Vulnerability type

*

Select the type of vulnerability, or specify a custom one.

- ☐ XSS
- ☐ CSRF
- ☐ Feature bug
- ☒ Other: DOS

Steps to reproduce

*

Describe the steps to reproduce the vulnerability.

The website is hosted on an Apache server. These websites are susceptible to Slow Loris attacks, and the programmers have not taken steps to mitigate this attack

Proof of concept

*

Provide a proof of concept for the vulnerability.

I have ran a script to run a Slow Loris attack. This attack tries to keep many connections to the target web server open and hold them open as long as possible.
This has brought the website down and is unusable.

Impact

*

Describe the impact of the vulnerability. How bad is it?

Severe; the website is easily DOSable, which means that this website can be brought down whenever an attacker wants.

Screenshots/attachments

Provide screenshots or other attachments to help explain the vulnerability.

Submitted files



fcs_37_4_1 - Utkarsh Arora.png

[Quoted text hidden]